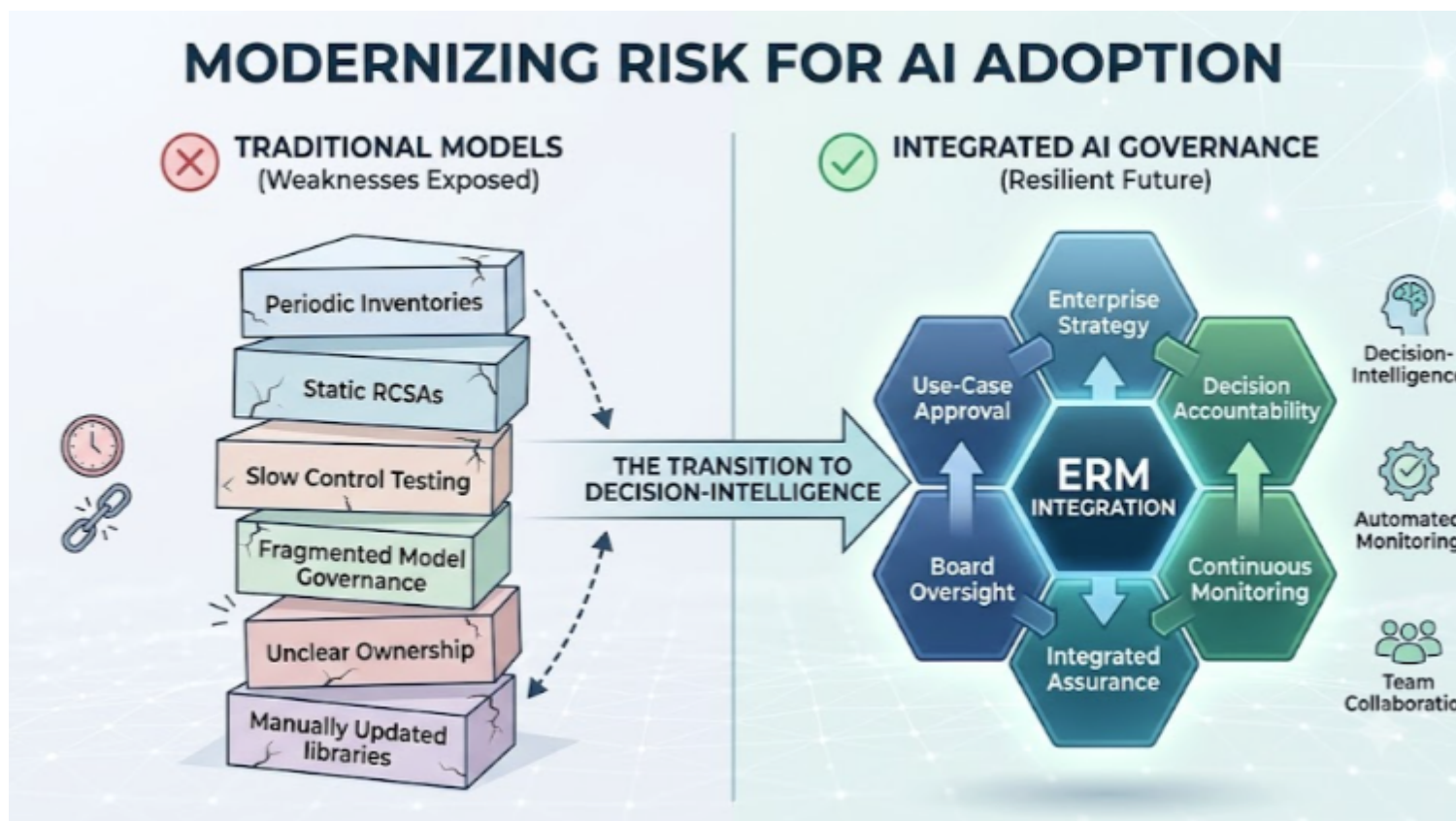


(1) AI Governance Is Exposing Weaknesses in Traditional Risk Models: Perspectives from Risk Leader



AI Governance - Exposing Weakness in Traditional ERM Models | Credit: AI Generated Image (Right-Click + New Tab)

The Future of Enterprise Risk Leadership | Article 4

CORE THESIS: AI governance is not a new risk category to be bolted onto legacy risk frameworks. It is a stress test of whether the enterprise can govern fast-moving, data-dependent, third-party-enabled, continuously learning systems at the speed of business decisions.

Disclaimer: This article reflects my independent professional perspectives and is shared in my personal capacity. The v

Executive Summary

Artificial intelligence is quickly becoming an enterprise capability, not a technology experiment. Boards and executive teams are seeing AI embedded in investment research, client communications, software development, cybersecurity operations, financial crime monitoring, HR processes, operational workflows, and third-party platforms. The governance question is no longer whether AI will be used. The question is whether organizations can govern AI use in a way that is safe, accountable, explainable, resilient, and strategically useful.

My core view as a ERM leader is direct: AI governance is exposing weaknesses that already existed in many traditional risk models. Siloed inventories, static risk taxonomies, slow control testing, fragmented model governance, unclear ownership, weak data lineage, and inconsistent third-party oversight were manageable when systems changed slowly. They are far less manageable when AI capabilities can be deployed through SaaS platforms, copilots, APIs, open-source models, and autonomous workflows in weeks or even days.

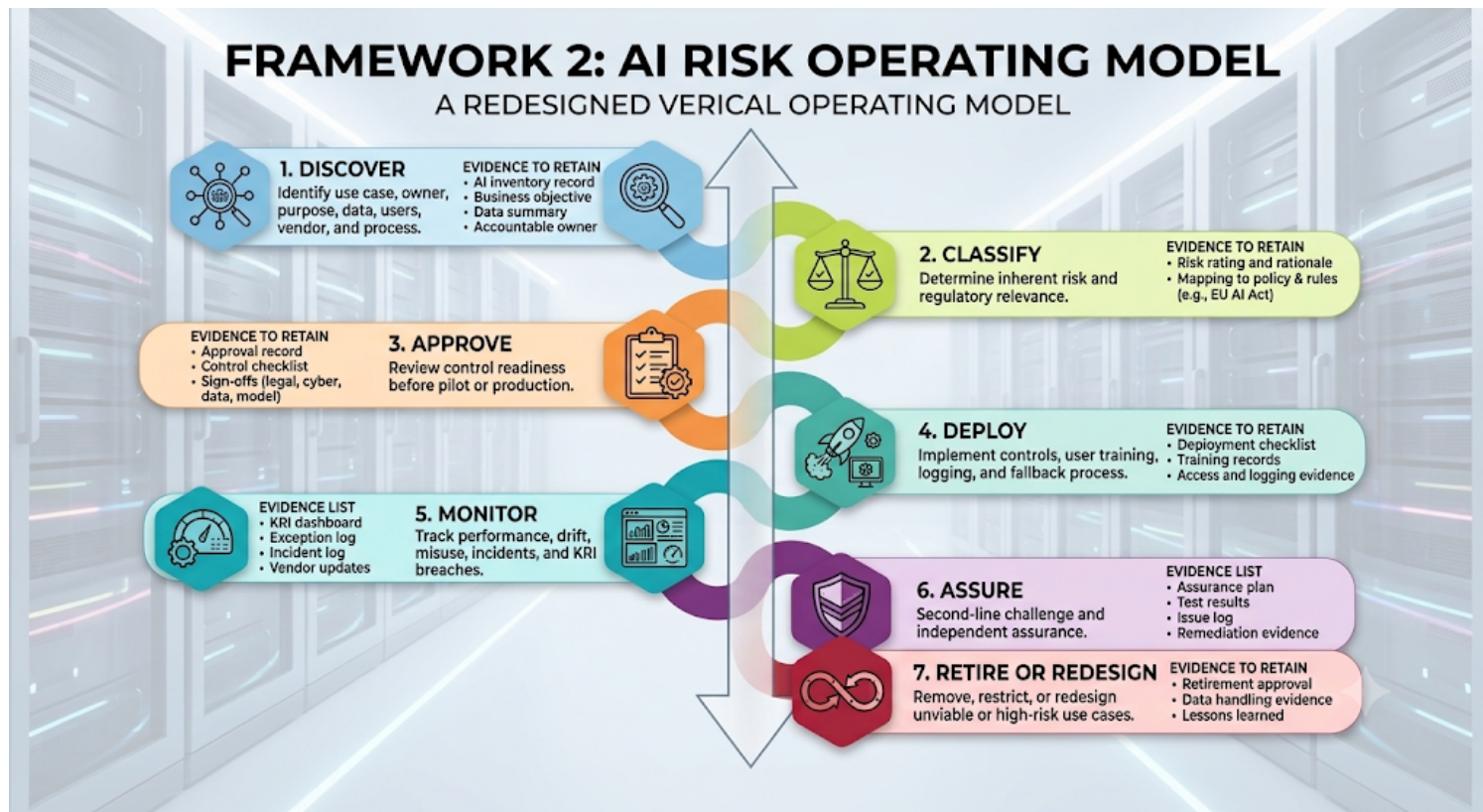
This article argues that AI risk should not be treated as a stand-alone compliance program. It should be integrated into ERM, technology risk, model risk, cyber, data governance, third-party risk, conduct risk, legal, compliance, operational resilience, and Internal Audit assurance. The strongest AI governance programs will not be the ones with the longest policy documents. **They will be the ones that connect AI use cases to business objectives, risk appetite, control ownership, monitoring, assurance, and board decision-making.**

1. Why AI Governance Matters Now

AI has crossed the boundary from experimentation to enterprise infrastructure. Many organizations began with low-risk productivity tools: summarization,

translation, coding support, research assistance, document drafting, and meeting notes. **The next wave is more consequential:** AI-assisted portfolio research, automated customer interactions, operational decision support, cyber detection, third-party monitoring, regulatory surveillance, and agentic workflows that can take actions across systems.

This creates a governance challenge because AI risk is not one risk. It is a bundle of risks that travel together: data leakage, biased or inaccurate outputs, model drift, hallucination, prompt injection, insecure integrations, opaque third-party dependencies, intellectual property exposure, privacy harm, regulatory breach, employee misuse, over-reliance, and operational disruption. In financial services and other highly regulated industries, these risks can quickly become conduct, fiduciary, resiliency, market integrity, and reputational issues.



AI Risk Operating Model Framework | Credit: AI Generated Image (Right-Click and Open in New Tab)

The NIST AI Risk Management Framework describes AI risk management as a way to improve the ability to incorporate trustworthiness considerations into the design, development, use, and evaluation of AI systems.

The EU AI Act takes a risk-based regulatory approach, with specific obligations for prohibited, high-risk, and general-purpose AI systems.

ISO/IEC 42001 introduces a management-system discipline for AI governance.

The direction of travel is clear: AI governance is becoming more formal, more auditable, and more board-visible.

2. The Problem: Traditional Risk Models Were Built for a Slower World

Many traditional risk programs still rely on periodic inventories, annual assessments, static RCSAs, manually updated control libraries, quarterly KRIs, committee papers, and issue remediation cycles. Those tools remain useful, but they were not designed for AI systems that can change based on data, model updates, prompt design, vendor release cycles, user behavior, and downstream integration patterns.

The first weakness is **inventory**. Many organizations do not have a complete view of where AI is being used. They may track internally developed models but miss embedded AI within SaaS products, vendor tools, browser extensions, productivity suites, developer platforms, marketing tools, and analytics workflows. **Without a complete inventory, there can be no reliable governance.**

The second weakness is **ownership**. AI use cases often sit between business, technology, data, legal, risk, compliance, cyber, and procurement. Everyone has a legitimate interest, but no one may own the end-to-end risk decision. **This creates a governance gap:** the business wants speed, technology enables deployment, legal reviews terms, cyber reviews access, risk asks for controls, compliance asks for regulatory mapping, and Internal Audit later asks who approved the use case.

The third weakness is **assurance**. Traditional assurance often arrives after deployment. AI requires pre-deployment challenge, ongoing monitoring,

and periodic independent review. If AI-enabled processes make or influence decisions, the organization needs assurance not only over model design, but also over data quality, intended use, user behavior, operational controls, vendor dependencies, incident response, and management accountability.

AI is not creating all-new governance problems. It is exposing the weaknesses that slow-moving systems allowed organizations to ignore.

3. The Risk Leader Perspective: AI Is a Decision Risk Before It Is a Technology Risk

A common mistake is to treat AI governance as a technology-risk exercise. That is too narrow. The real risk is not that AI exists. ***The risk is that AI changes decisions in ways the organization does not understand, approve, monitor, or control.***

This matters because AI rarely fails in isolation.

A flawed model output may cause an employee to send inaccurate client information.

A coding assistant may introduce security vulnerabilities.

A research tool may fabricate sources.

A chatbot may provide inconsistent disclosures.

An AI-enabled vendor may process data in a way that violates contractual or regulatory expectations.

An autonomous agent may take an action that no human explicitly intended.

In each case, the technology is only part of the story. The larger issue is decision accountability.

For ERM, the practical question is therefore simple: ***where does AI influence business decisions, operational actions, client outcomes, risk monitoring, or control execution?*** Once that question is answered, governance can become concrete. Risk appetite can be applied. Controls can be designed. Monitoring can be established. Assurance can be planned. Board reporting can become meaningful.

Perspective: Risk is not managed in the abstract. Decisions are managed. AI governance must start by identifying where AI changes decisions, actions, obligations, or outcomes

4. Practical Example: AI in Asset Management

Consider an asset manager deploying AI across three areas: investment research summarization, client reporting drafts, and operations exception management. None of these use cases may appear catastrophic in isolation. Together, however, they create an enterprise governance challenge.

In investment research, AI may accelerate analyst productivity but also create risks around source reliability, copyright, hallucination, over-reliance, and investment thesis documentation.

In client reporting, AI may improve efficiency but introduce risks around accuracy, disclosure, tone, personalization, suitability, and record-keeping.

In operations, AI may help triage exceptions but could misclassify breaks, delay escalation, or embed bias into prioritization logic.

If the same cloud provider, foundational model provider, or SaaS platform supports all three, concentration risk also increases.

A legacy risk program might review each use case separately. A modern Risk leader should ask a different set of questions:

What enterprise AI principles apply to all three?

What data is used?

Who approves model-assisted decisions?

What requires human review?

What evidence is retained?

What KRIs indicate drift, misuse, performance degradation, or control failure?

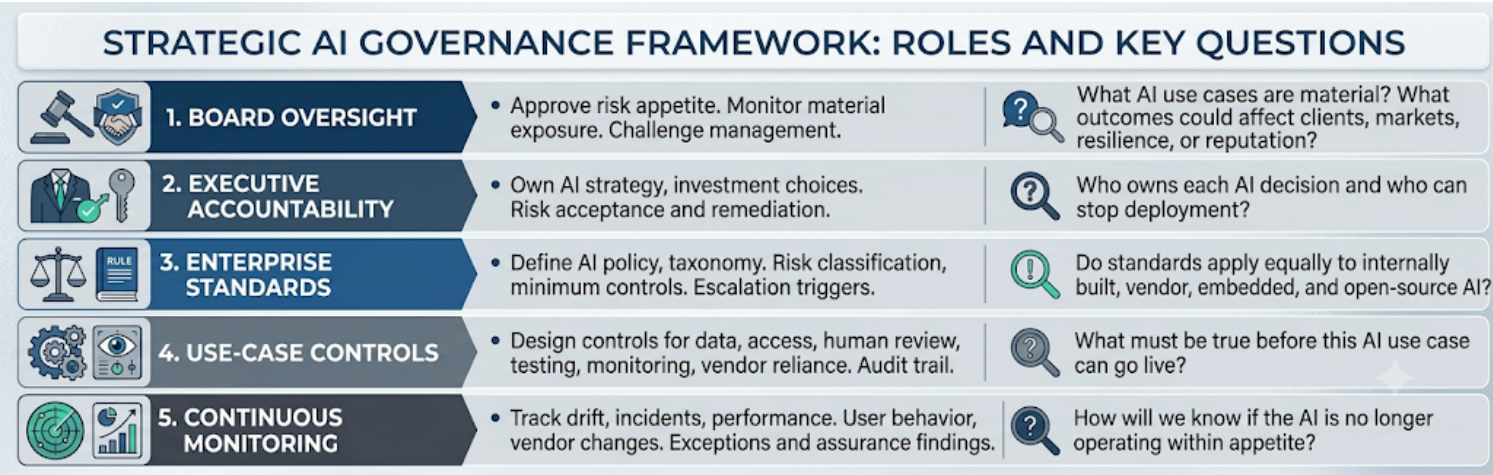
What is the fallback process if the AI tool is unavailable?

Which vendor dependencies are critical?

What does the board need to know?

5. Enterprise AI Governance Model

AI governance should connect strategy, use-case approval, risk classification, control design, monitoring, assurance, and board oversight. In my view, the operating model should be based on five layers: board oversight, executive accountability, enterprise standards, use-case controls, and continuous monitoring. The model below is deliberately practical. It avoids the trap of making AI governance either a legal compliance exercise or a technology architecture exercise. It positions AI governance as an enterprise decision system.

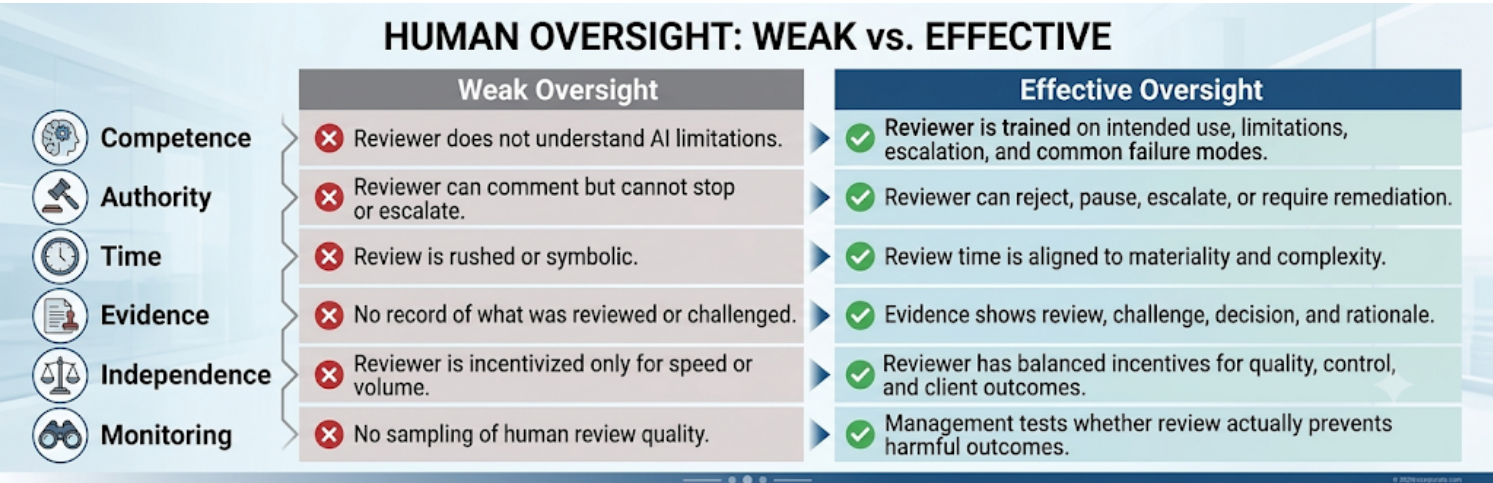


Enterprise AI Governance Model | Credit: AI Generated Image (Right-Click and Open in New Tab)

6. Human Oversight: The Control Most Likely to Fail

Most AI governance frameworks emphasize human oversight. **That is necessary, but insufficient.** Human oversight can become a comforting phrase that masks weak control design. A human reviewer who does not understand the model, lacks time, trusts automation too much, or has no authority to stop deployment is not an effective control.

The danger is automation bias. People tend to over-rely on machine-generated outputs, especially when they are presented confidently, quickly, and in professional language. In high-volume environments, human review can become procedural rather than substantive. **The control may exist on paper but fail in practice.**



Human Oversight Effectiveness Test. | Credit: AI Generated Image (Right-Click and Open in New Tab)

Effective human oversight requires role clarity, training, escalation authority, sampling, challenge expectations, evidence retention, and performance metrics. It also requires defining which decisions must remain human-owned. Not every AI output requires the same level of review. A grammar suggestion is not the same as a client recommendation, investment signal, fraud alert, hiring decision, or operational escalation.

Human-in-the-loop is not a control unless the human has competence, time, authority, evidence, and the courage to challenge the machine.

7. Agentic AI Raises the Stakes

Generative AI primarily produces content or recommendations. Agentic AI can take actions. That distinction is critical for risk governance. When an AI

agent can query data, draft messages, execute workflows, update systems, trigger tickets, call APIs, or coordinate with other agents, the risk profile changes materially.

Agentic AI introduces new control questions:

- What actions may the agent take?
- What systems can it access?
- What approvals are required?
- What transaction limits apply?
- Can the agent override controls?
- How are instructions logged?
- How are prompts protected?
- Can malicious inputs manipulate the agent?
- What is the kill switch?
- How quickly can the organization detect abnormal behavior?

For ERM, the governance lesson is clear: autonomy should be granted progressively, based on risk classification, control maturity, evidence of performance, and assurance results. The enterprise should not move from AI-assisted drafting to autonomous execution without a formal escalation in governance, monitoring, and accountability.

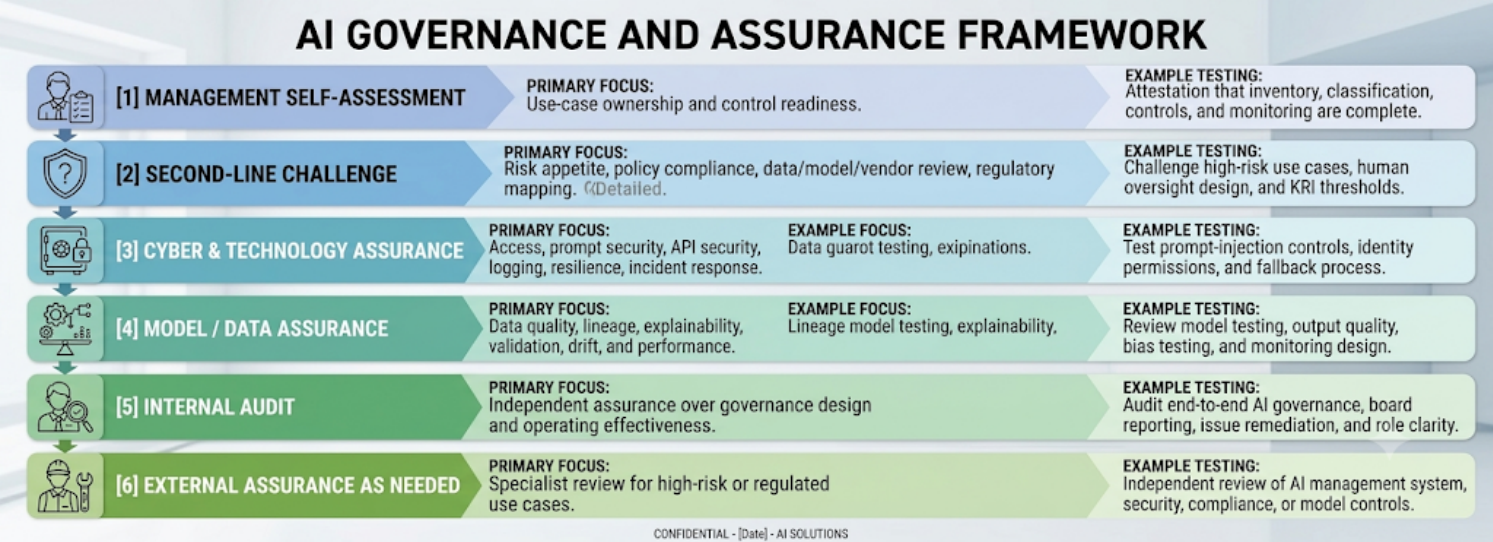
Perspective: The governance difference between a chatbot and an autonomous agent is the difference between advice and action. The control framework must change accordingly.

8. AI Assurance: From Periodic Review to Continuous Confidence

Internal Audit, Risk, Compliance, Cyber, Legal, Data Governance, and Model Risk each have a role in AI assurance. The challenge is to avoid fragmented assurance. **If every function reviews AI separately using different criteria, management will face duplicated requests and the board will receive inconsistent conclusions.**

AI assurance should be integrated across the lifecycle.

- Before deployment, assurance should evaluate use-case classification, data provenance, model selection, vendor due diligence, legal and regulatory mapping, control design, and human oversight.
- During operation, assurance should evaluate monitoring, drift, incident response, user behavior, access control, output quality, exception handling, and policy compliance.
- After material change or incident, assurance should evaluate root cause, remediation, control redesign, and reporting.



The IIA's Three Lines Model remains relevant because accountability and independence still matter. However, AI makes coordination more important. **The board does not need ten disconnected opinions on AI risk. It needs one coherent view of whether AI is being adopted responsibly, safely, and within risk appetite.**

9. What Boards Should Expect

Boards should not be expected to understand every technical detail of AI architecture. They should expect management to present a clear view of AI strategy, risk appetite, material use cases, governance structure, control maturity, incidents, regulatory exposure, third-party dependencies, and assurance results.

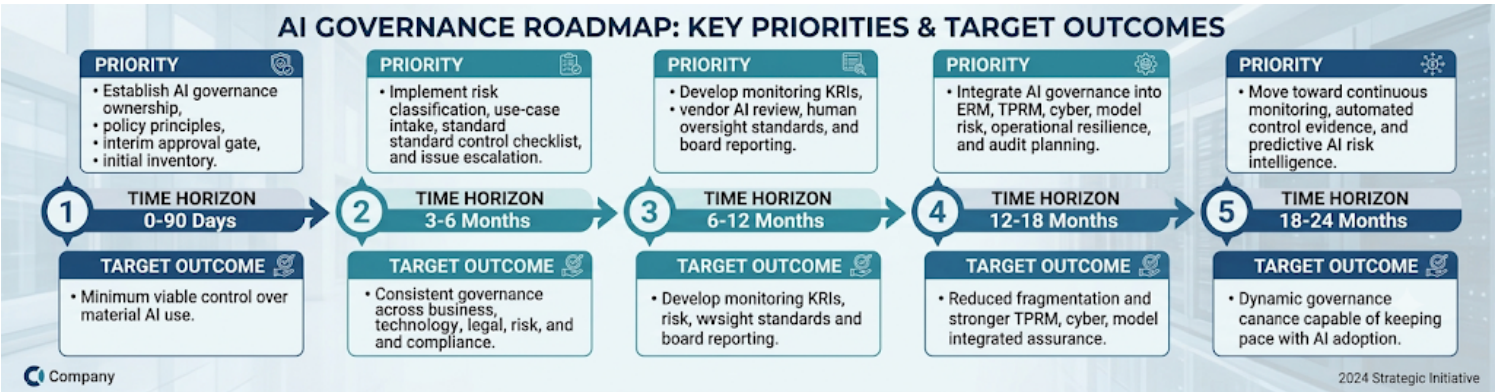
A useful board AI report should answer five questions:

- Where is AI being used?
- Which use cases are most material?
- What decisions or outcomes are affected?
- What controls and monitoring are in place?
- What assurance has been performed, and what issues require board attention?

Boards should also push management to avoid both extremes: uncontrolled experimentation and governance paralysis. AI governance must protect the organization without preventing responsible innovation. **The goal is not to slow every AI use case. The goal is to accelerate the right use cases with clear guardrails.**

10. 24-Month Implementation Roadmap

Organizations do not need to build a perfect AI governance program before taking action. They need a sequenced roadmap that establishes minimum viable governance quickly and matures over time. The roadmap should begin with inventory, policy, ownership, and risk classification. It should then move toward integrated controls, monitoring, assurance, and board reporting. Over time, the organization should develop predictive indicators and continuous AI risk intelligence.



AI Governance Roadmap | Credit: AI Generated Image (Right-Click and Open in New Tab)

Conclusion: AI Governance Is a Test of Enterprise Risk Leadership

AI governance is not simply a regulatory requirement, model-risk exercise, cyber control, data policy, procurement checklist, or innovation program. It is a test of enterprise risk leadership. It tests whether the organization can connect strategy to risk appetite, risk appetite to controls, controls to monitoring, monitoring to assurance, and assurance to board-level decisions.

The organizations that succeed will not be the ones that ban AI or deploy it everywhere without discipline. They will be the ones that make AI adoption risk-intelligent: fast enough to create value, disciplined enough to protect trust, and transparent enough to withstand scrutiny.

For ERM, the opportunity is significant. AI gives risk leaders a chance to move beyond reporting and become architects of responsible innovation. The question is not whether AI belongs in the risk framework. The question is whether the risk framework is strong enough, integrated enough, and dynamic enough for AI.

Closing Thoughts: The future of AI governance will be won by organizations that convert risk management from a gatekeeping function into a decision-intelligence capability

Board and Executive Discussion Questions

- Where is AI currently being used across the enterprise, including embedded AI within vendor and SaaS platforms?
- Which AI use cases materially affect clients, employees, financial outcomes, controls, or regulatory obligations?
- Who owns AI risk decisions, and who has authority to approve, pause, or stop deployment?
- How does the organization distinguish low-risk productivity use from high-risk decision support or autonomous action?
- What data can be used in AI tools, and how is confidential, client, personal, and proprietary information protected?
- What human oversight is required, and how do we know that oversight works in practice?
- How are AI vendor dependencies, concentration risks, and contractual obligations monitored?
- What indicators would show that an AI use case is drifting, being misused, or producing harmful outcomes?
- How is AI governance integrated into ERM, cyber, compliance, operational resilience, third-party risk, model risk, and Internal Audit?
- What should the board see quarterly to understand whether AI adoption remains within risk appetite?

References and Source Links

- NIST.** Artificial Intelligence Risk Management Framework (AI RMF 1.0), 2023. <https://www.nist.gov/itl/ai-risk-management-framework>
- NIST.** Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, 2024. <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>
- European Union.** Regulation (EU) 2024/1689, Artificial Intelligence Act, Official Journal, 2024. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng>
- ISO.** ISO/IEC 42001:2023 Artificial intelligence – Management system. <https://www.iso.org/standard/42001>
- OECD.** OECD AI Principles. <https://oecd.ai/en/ai-principles>
- The Institute of Internal Auditors.** The IIA Three Lines Model: An update of the Three Lines of Defense, 2020 / updated 2024. <https://www.theiia.org/en/content/position-papers/2020/the-iias-three-lines-model-an-update-of-the-three-lines-of-defense/>
- COSO.** Enterprise Risk Management – Integrating with Strategy and Performance. <https://www.coso.org/enterprise-risk-management>
- ISO.** ISO 31000:2018 Risk management – Guidelines. <https://www.iso.org/standard/65694.html>
- Basel Committee on Banking Supervision.** Principles for Operational Resilience, 2021. <https://www.bis.org/bcbs/publ/d516.htm>